

Security+ 1.4 · Hashing & Digital Signatures

Mestre CyberSec · Aula 1.4 — Hashing & Digital Signatures (10:24) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Hash = impressão digital mão única: SHA-256/SHA-3 padrão; MD5/SHA-1 quebrados. Assinatura digital = cifrar o hash com a chave PRIVADA — qualquer um valida com a pública. Garante integridade + autenticidade + non-repudiation (3 objetivos).

💡 Highlights que a prova CompTIA cobra

- SHA-256 padrão; MD5/SHA-1 quebrados (collision)
- Assinatura = hash cifrado com chave PRIVADA de quem assina
- Avalanche effect: 1 bit mudou = hash inteiro mudou

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'provides integrity but not confidentiality' = hash
- 'cannot deny that they signed' = digital signature (non-repudiation)

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 1.4 — Hashing & Digital Signatures)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Função Hash (Hashing) (N/A)

Função criptográfica de mão única que transforma dados de qualquer tamanho em um resumo de tamanho fixo; fornece integridade, mas não confidencialidade nem autenticação por si só.

⚠️ **Armadilha CompTIA:** Se a prova disser 'integridade, mas não confidencialidade', a resposta é hash. Hashes não são criptografia reversível.

• SHA-256 (Algoritmo de Hash Seguro de 256 bits)

Algoritmo de hash SHA-2 que produz um resumo de 256 bits e é o padrão atual para integridade e assinaturas digitais em cenários da prova CompTIA.

⚠️ **Armadilha CompTIA:** Escolha SHA-256 quando a questão pedir hash seguro e atual; MD5 e SHA-1 são considerados quebrados.

• SHA-3 (Algoritmo de Hash Seguro 3)

Padrão de hash mais recente do NIST baseado em Keccak, usado como alternativa segura ao SHA-2 e não vulnerável a ataques de colisão de MD5/SHA-1.

⚠️ **Armadilha CompTIA:** SHA-3 é padrão seguro, mas SHA-256 ainda é a escolha mais comum em questões; ambos são aceitos como fortes.

• MD5 (Resumo de Mensagem 5)

Algoritmo de hash mais antigo de 128 bits considerado quebrado devido a ataques práticos de colisão; não deve ser usado para integridade ou assinaturas digitais.

⚠️ **Armadilha CompTIA:** Se a questão mencionar MD5, geralmente é a resposta errada/fraca; indique colisões e obsolescência.

• SHA-1 (Algoritmo de Hash Seguro 1)

Algoritmo de hash de 160 bits obsoleto porque colisões foram demonstradas; não é mais confiável para assinaturas digitais ou integridade.

⚠️ **Armadilha CompTIA:** Assim como MD5, SHA-1 é considerado quebrado; prefira SHA-256 ou SHA-3.

• Colisão (N/A)

Situação em que duas entradas diferentes produzem o mesmo resumo hash; quebra garantias de integridade e é o motivo pelo qual MD5 e SHA-1 são obsoletos.

⚠️ **Armadilha CompTIA:** Palavra-chave 'collision' aponta para algoritmo de hash quebrado (MD5/SHA-1), não para criptografia simétrica.

• Assinatura Digital (N/A)

Mecanismo criptográfico em que um hash de uma mensagem é cifrado com a chave privada do remetente; a verificação usa a chave pública do remetente e fornece integridade, autenticação e não repúdio.

⚠️ **Armadilha CompTIA:** 'Cannot deny that they signed' = non-repudiation, provided by digital signature. Lembre: chave privada assina, chave pública valida.

• Efeito Avalanche (N/A)

Propriedade de hashing forte em que uma pequena mudança na entrada, mesmo um bit, produz um resumo hash completamente diferente.

⚠️ **Armadilha CompTIA:** Se a questão mostrar dois hashes totalmente diferentes para entradas quase iguais, é o avalanche effect.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um administrador de sistemas de uma instituição de saúde baixa uma ISO do servidor Ubuntu do site oficial do fabricante. Antes de instalá-la em um host de produção, o administrador quer confirmar que o arquivo não foi alterado durante o download nem substituído por uma cópia maliciosa em um espelho. Qual ação MELHOR atinge esse objetivo?

- A) Calcular o digest SHA-256 da ISO baixada e compará-lo com o digest publicado pelo fabricante
- B) Confirmar que o tamanho do arquivo ISO corresponde ao tamanho listado na página de download
- C) Escanear a ISO com o agente antivírus do endpoint e confirmar que nenhum malware foi detectado
- D) Verificar se o certificado TLS do site de download foi emitido por uma autoridade certificadora confiável

QUESTÃO 2 · CENÁRIO DE EXAME

Durante uma avaliação de segurança de um aplicativo de folha de pagamento legado, um analista descobre que o aplicativo verifica a integridade dos relatórios exportados usando digests MD5. O analista reporta isso como um achado de alto risco. Qual afirmação MELHOR explica a fraqueza técnica desse design?

- A) A resistência a colisões do MD5 está quebrada, então dois relatórios diferentes podem produzir um digest idêntico
- B) O MD5 usa uma chave de 512 bits curta demais para resistir a hardware moderno de força bruta
- C) O MD5 é um algoritmo simétrico, então a chave de verificação precisa ser compartilhada com o destinatário
- D) O MD5 produz um digest de tamanho variável que não pode ser comparado de forma confiável entre sistemas

QUESTÃO 3 · CENÁRIO DE EXAME

Uma analista financeira recebe um contrato por e-mail de um parceiro de negócios contendo uma assinatura digital. Para validar a assinatura e confirmar tanto a integridade da mensagem quanto a identidade do remetente, qual chave a analista deve usar?

- A) A chave pública do parceiro
- B) A chave privada do parceiro
- C) A própria chave privada da analista
- D) A própria chave pública da analista

QUESTÃO 4 · CENÁRIO DE EXAME

O departamento jurídico exige que as aprovações de releases de software sejam criptograficamente vinculadas ao engenheiro individual que as aprovou, de modo que ele não possa depois negar ter autorizado a liberação. Qual controle MELHOR atende a esse requisito?

- A) Assinar digitalmente cada aprovação com a chave privada do engenheiro aprovador
- B) Criptografar cada aprovação com uma chave AES compartilhada por toda a equipe de engenharia
- C) Gerar um HMAC de cada aprovação usando um segredo compartilhado armazenado no servidor de build
- D) Armazenar um hash de cada aprovação em uma tabela de banco de dados somente leitura

QUESTÃO 5 · CENÁRIO DE EXAME

Um analista de malware observa que dois arquivos executáveis completamente diferentes, um benigno e um malicioso, produzem exatamente o mesmo digest SHA-1 quando analisados pelo ferramental do laboratório. O analista escala esse achado para a equipe de segurança. Qual evento criptográfico ocorreu?

- A) Uma colisão na função hash
- B) Um erro de truncamento introduzido pela ferramenta de hash do analista
- C) Uma recuperação bem-sucedida de chave privada contra o certificado de assinatura
- D) Um ataque de dicionário offline contra as credenciais embutidas no executável

QUESTÃO 6 · CENÁRIO DE EXAME

Um desenvolvedor altera um único caractere em um arquivo de configuração e depois regenera seu digest SHA-256 para o manifesto de implantação. O engenheiro de segurança percebe que aproximadamente metade dos bits do digest mudou em relação à versão anterior. Qual propriedade das funções hash criptográficas esse comportamento ilustra?

- A) O efeito avalanche
- B) O paradoxo do aniversário
- C) Key stretching (alongamento de chave)
- D) Sigilo persistente (forward secrecy)

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa de software distribui um cliente desktop desenvolvido internamente por meio de seu site público. Os clientes devem poder confirmar tanto que o binário se originou da empresa quanto que não foi modificado desde a compilação. Qual mecanismo a empresa deve implementar para fornecer ambas as garantias aos clientes?

- A) Assinar digitalmente o binário com um certificado cuja chave privada é mantida em um módulo de segurança de hardware
- B) Publicar o checksum MD5 do binário ao lado do link de download
- C) Comprimir o binário em um arquivo protegido por senha
- D) Publicar o digest SHA-256 do binário por um canal HTTP não autenticado

QUESTÃO 8 · CENÁRIO DE EXAME

Um arquiteto de segurança está documentando os serviços de segurança entregues por um componente que apenas calcula digests SHA-3 de mensagens e os armazena. O arquiteto precisa declarar com precisão qual objetivo de segurança NÃO é fornecido por esse componente. Qual objetivo deve ser listado como não fornecido?

- A) Confidencialidade
- B) Integridade
- C) Detecção de modificação acidental
- D) Fornecimento de uma representação de tamanho fixo para dados de tamanho variável

QUESTÃO 9 · CENÁRIO DE EXAME

Dois servidores internos trocam mensagens de inventário protegidas com um HMAC derivado de uma chave pré-compartilhada que ambos os servidores possuem. Uma disputa surge depois sobre qual servidor realmente enviou uma mensagem específica. Por que o HMAC não resolve essa disputa?

- A)** Porque ambos os servidores detêm o mesmo segredo compartilhado, qualquer um deles poderia ter gerado o HMAC, logo não há não repudição
- B)** Porque o HMAC usa uma função hash, o conteúdo da mensagem não pode ser recuperado para provar o que foi enviado
- C)** Porque a chave pré-compartilhada é simétrica, é matematicamente inviável calcular um HMAC em tempo real
- D)** Porque os digests HMAC são truncados em 128 bits, a identidade do remetente se perde durante a transmissão

QUESTÃO 10 · CENÁRIO DE EXAME

Um contratado do governo deve selecionar um algoritmo de hash para um novo sistema que processa informações controladas não classificadas. O contrato exige um algoritmo aprovado pelo FIPS que ofereça a mais forte resistência disponível a ataques de extensão de comprimento e de colisão e que não se baseie na construção Merkle-Damgård. Qual família de algoritmos o contratado deve selecionar?

- A)** SHA-3
- B)** SHA-1
- C)** MD5
- D)** RIPEMD-160

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Calcular o digest SHA-256 da ISO baixada e compará-lo com o digest publicado pelo fabricante

Uma função hash criptográfica funciona como uma impressão digital de mão única do arquivo. Recalcular o digest SHA-256 localmente e compará-lo ao valor publicado pelo fabricante detecta qualquer modificação de um único bit feita em trânsito ou por um espelho. O tamanho do arquivo e a varredura antivírus podem ser contornados por um arquivo modificado, e um certificado TLS válido protege apenas os dados em trânsito até aquele site — não prova que o arquivo armazenado está íntegro.

Questão 2: Alternativa A — A resistência a colisões do MD5 está quebrada, então dois relatórios diferentes podem produzir um digest idêntico

O MD5 é uma função hash, não um algoritmo de cifra, e foi demonstrado que é vulnerável a ataques de colisão práticos: um atacante pode criar duas entradas diferentes que geram o mesmo digest MD5. Isso destrói a garantia de integridade, pois um relatório adulterado poderia carregar o mesmo digest do original. O MD5 não usa chaves e sempre produz uma saída fixa de 128 bits.

Questão 3: Alternativa A — A chave pública do parceiro

Em um esquema de assinatura digital, o assinante aplica hash na mensagem e cifra o hash com sua própria chave privada. Qualquer destinatário valida a assinatura descriptografando o hash com a chave pública do assinante, amplamente distribuída, e comparando-o com um hash recém-calculado da mensagem. A posse da chave pública do assinante é o que torna a verificação possível sem expor o segredo de assinatura.

Questão 4: Alternativa A — Assinar digitalmente cada aprovação com a chave privada do engenheiro aprovador

A não repudição exige que a prova de origem esteja atrelada ao segredo exclusivo de uma parte. Uma assinatura digital criada com a chave privada de um indivíduo pode ser validada por qualquer pessoa com a chave pública desse indivíduo, e somente o detentor da chave privada poderia tê-la produzido. Controles simétricos como chaves AES compartilhadas ou segredos HMAC não fornecem não repudição, pois qualquer detentor do segredo compartilhado poderia ter gerado o mesmo valor. Um hash simples prova apenas integridade, sem vínculo de identidade.

Questão 5: Alternativa A — Uma colisão na função hash

Uma colisão ocorre quando duas entradas distintas produzem a mesma saída de hash. Foi demonstrado que o SHA-1 é propenso a colisões, motivo pelo qual está depreciado para uso em integridade e assinaturas. O truncamento de hash por uma ferramenta é um problema de configuração e não um evento criptográfico, e nem recuperação de chave nem ataques de dicionário têm relação com dois arquivos diferentes compartilhando um digest.

Questão 6: Alternativa A — O efeito avalanche

O efeito avalanche é a propriedade pela qual uma mudança mínima na entrada (mesmo um bit) produz um digest de saída drasticamente diferente, com cerca de metade dos bits invertidos. É isso que torna os hashes úteis para detectar adulteração: um atacante não consegue modificar um arquivo incrementalmente mantendo o digest parecido. O paradoxo do aniversário está relacionado à probabilidade de colisão, o key stretching retarda a adivinhação por força bruta de senhas, e o sigilo persistente protege chaves de sessão passadas.

Questão 7: Alternativa A — Assinar digitalmente o binário com um certificado cuja chave privada é mantida em um módulo de segurança de hardware

A assinatura de código usa uma assinatura digital gerada com a chave privada do editor; os clientes a validam com a chave pública do editor presente no certificado de assinatura de código. Isso prova simultaneamente a integridade e autentica a origem e, por ser uma chave assimétrica, sustenta a não repudição. Um checksum publicado sozinho prova integridade, mas não origem; o MD5 é quebrado para colisões; e enviar o digest por canal não autenticado permitiria a um atacante substituir o digest junto com o binário.

Questão 8: Alternativa A — Confidencialidade

O hashing é uma transformação de mão única que sustenta a verificação de integridade: qualquer alteração na mensagem altera o digest. No entanto, ele não realiza cifragem, então o conteúdo da mensagem permanece legível para quem tiver

acesso, ou seja, a confidencialidade não é fornecida. Integridade, detecção de alteração e a produção de um digest de tamanho fixo a partir de entradas de tamanho arbitrário são todas propriedades inerentes a uma função hash.

Questão 9: Alternativa A — Porque ambos os servidores detêm o mesmo segredo compartilhado, qualquer um deles poderia ter gerado o HMAC, logo não há não repudição

O HMAC fornece integridade e autenticidade entre partes que compartilham uma chave secreta, mas não consegue estabelecer não repudição. Como ambos os servidores possuem a chave idêntica, qualquer um deles poderia ter produzido o valor, então um terceiro não pode atribuir uma mensagem específica a um deles. A confidencialidade da mensagem é irrelevante para essa disputa, o cálculo de HMAC é eficiente e o tamanho do digest não é o motivo da falha de atribuição.

Questão 10: Alternativa A — SHA-3

O SHA-3 é um padrão aprovado pelo NIST construído sobre a construção sponge, e não sobre Merkle-Damgård, o que o torna inerentemente resistente a ataques de extensão de comprimento e oferece forte resistência a colisões. Tanto o SHA-1 quanto o MD5 estão depreciados devido a colisões demonstradas, e o RIPEMD-160 não é aprovado pelo FIPS nem tão resistente a colisões quanto as opções modernas SHA-2/SHA-3.